S. Arshad
ITA1439 19242580

1) Hacker classification & ethical principles.

A) A hacker is a person who uses technical knowledge and computer skills to identify, investigate or exploit vulnerabilities in computer systems, networks or applications.

33/50 66%

classification of hackers

person	classification	Reason
security firm hired by the bank	white hat hacker	performs authorized penetration testing to identify
former employee using old credentials	Black hat	misuses previously granted access to view the customer
student using a downloaded attack tool	script kiddie	uses ready-made hacking tools without authorization.

Ethical principles for security testers:

1) written authorization: obtain formal permission from the bank before begining testing.

2) Agreed scope : Test only approved websites, servers, application & networks.

3) SQL Injection, IT ACT 2000 AND Vulnerability Disclosure.

A) A student discovers an SQL Injection vulnerability in another university's e-learning portal, potentially exposing the personal information of 20,000 students.

Relevant Provisions:

- Section 43 : covers unauthorized access
- section 66 : Makes acts covered by section 43
- Section 72 : concerns breaches of confidentiality & privacy by persons.

Method	Description	Risks
Full Disclosure	publicly revealing the vulnerability	creates awareness but may enable attacks
Responsible	privately reporting the vulnerability & coordinating	protects users & allows Developers.

Ethical hacking methodology & Roles of Engagement

Phase	objective
1) Reconnaissance	collect information about the target system, Domain
2) scanning	Identify active systems, open ports, running services & possible vulnerabilities.
3) Gaining Access	Safely validate whether identified vulnerabilities could permit unauthorized access.
4) Maintaining Access	Assess persistance risks using approved

Rules of Engagement :

1) In-scope Target : Approved Ip addresses, Domains, application.

2) Testing window : Authorized dates and times for conducting the assessment.

(b) Passive & Active footprinting

Passive footprinting	Active footprinting
Collects information without directly interacting with the target infrastructure.	Interacts directly with target systems or services.
Uses public websites, search engines & registration	Uses direct DNS queries, network scanning & service enumeration

Tools used :

1) whois lookup : whois retailco.example

2) DNS lookup using nslookup or dig : nslookup retailco.example
dig retailco.example

3) Search-engine operators:

Site : retailco.example

Filetype:pdf site : retailco.example

intitle : login site: retailco.example

Analyzed
Analyzing
...
ional DOCX Assignment
+ Ask ChatGPT
Think
Shaik Arshad
Go
Search
ENG US

DNS Zone Transfer & security risks.

A DNS zone transfer is a mechanism used to replicate DNS records from a primary DNS server to authorized secondary DNS servers.

Ex: dig axfr example.com @ns1.example.com

How Does DNS zone works:

A secondary DNS server requests zone information from the primary server.

Analysis of exposed DNS records:

DNS record	Information	Possible security risks
www-203.0.113.10	public web-server IP address	helps identify the website
vpn-203.0.113.25	vpn gateway address	Identifies a remote-access
hr-portal-10.105.20	Internal HR Application	Reveals internal naming

Q) Social engineering Attacks & Countermeasures?

A) Social engineering is a cybersecurity attack technique in which attackers manipulate people into revealing confidential information, performing unsafe actions.

Identification of attacks:

Scenario	Attack type	psychological principle
Fake IT-help Desk email requesting	phishing	Authority, urgency & fear

Countermeasures:

1) Technical countermeasures:

configure email security controls such as SPF, DKIM

2) procedural countermeasures:

Receive employees to verify unusual requests through trusted channels.